

On the applicability of security and privacy threat modeling for blockchain applications

Dimitri Van Landuyt, Laurens Sion, Emiel Vandeloo, and Wouter Joosen

imec-DistriNet, KU Leuven,
B-3001 Leuven
`first.last@cs.kuleuven.be`

Abstract. Elicitative threat modeling approaches such as Microsoft STRIDE and LINDDUN for respectively security and privacy use Data Flow Diagrams (DFDs) to model the system under analysis. Distinguishing between external entities, processes, data stores and data flows, these system models are particularly suited for modeling centralized, traditional multi-tiered system architectures.

This raises the question whether these approaches are also suited for inherently decentralized architectures such as distributed ledgers or blockchains, in which the processing, storage, and control flow is shared among many equal participants

To answer this question, we perform an in-depth analysis of the compatibility between blockchain security and privacy threat types documented in literature and these threat modeling approaches. Our findings identify areas for future improvement of elicitive threat modeling approaches.

Keywords: Threat modeling · STRIDE · LINDDUN · blockchain.

1 Introduction

Threat modeling [24, 28, 25] involves the systematic investigation of threats to software-intensive systems, and is performed by evaluating generic and well-known threat types or threat categories. Threat elicitation approaches such as Microsoft’s STRIDE [25] and LINDDUN [8] act upon an end-to-end system model encoded in a Data Flow Diagram (DFD) and rigorously examine the applicability and likelihood of threat types at an intricate level of granularity in a software architecture. Given their versatility, these methods are increasingly adopted in practice, and different tool implementations are in existence [26, 19, 24]. Essentially distinguishing between user entities, processing elements, data storage elements, and data flows, DFDs are created with abstractions that are particularly well-aligned to traditional, centralized, multi-tier architectures.

This raises the key question whether existing threat elicitation methods and tools can be applied successfully to more contemporary decentralized architectures. In this paper, we evaluate this question in the context of distributed ledger architectures, also called *blockchains*. Blockchain as an architectural style is built upon a complex security model that integrates cryptographic principles with

game-theoretic aspects to maintain incentive compatibility of all participants in an open peer-to-peer based participation model. Emerging from the context of financial systems and crypto-currencies, the architectural principles of blockchain are increasingly being adopted for decentralized transaction-based data storage and processing across diverse applications [5].

We adopt the following approach: in a first step, we gather existing knowledge on blockchain security and privacy threat and attack types through literature review and existing survey studies [6], and cluster these into broader threat types specific to blockchain. In a second step, we explore the notion of *compatibility* between these threat types and the STRIDE and LINDDUN threat elicitation frameworks. We more precisely assess the extent to which the blockchain-specific threats can or *could* be identified by means of these approaches. To this end, we define an objective and categorical assessment scale. The findings and implications of this study allow us to highlight open challenges and define a roadmap for ongoing threat modeling research.

The considerable amount of attention spent on blockchain systems has led to the identification a wide range of blockchain-specific attacks and threat types [6]. Since these threat types mainly focus on crypto-currencies such as Bitcoin [20], most of the threat types discussed in this article focus on Bitcoin by intent, but are nonetheless applicable in the wider context of proof-of-work (PoW)-based distributed ledgers. Different types of blockchain systems (e.g., involving *smart contracts*) are not explicitly studied, and the investigation of threat types specific to these technologies is considered part of future work.

Recently emerging threat modeling approaches such as ABC [1] are specifically tailored for crypto-currency systems. Such alternative approaches represent a departure from threat modeling approaches that are meant to be versatile and applicable in a technology- and domain-agnostic context.

This paper is structured as follows: Section 2 discusses the necessary background on threat modeling and blockchain systems. Then, Section 3 lists the most prominent categories of security and privacy threats, whereas Section 4 presents an assessment of the compatibility of these threat types with the existing models of STRIDE and LINDDUN. Section 5 finally concludes the paper.

2 Background

This section first introduces threat modeling, and then provides a brief introduction to the main principles behind blockchains and distributed ledgers.

Threat modeling. Threat modeling refers to a number of architecture-centric analysis approaches to identify security- and privacy-related design flaws, potential threats to the correct and fair workings of a software-intensive system. STRIDE [25] and LINDDUN [8] are acronyms¹ of *threat categories* for respec-

¹ STRIDE: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege;

LINDDUN: Linkability, Identifiability, Non-repudiation, Detectability, Disclosure of information, Unawareness, Non-compliance

tively security and privacy. These threat categories are further refined into more concrete *threat types* in so-called *threat trees*. In these elicitative threat modeling approaches, the system under analysis is modeled as a Data Flow Diagram (DFD) constituting of *external entities*, *processes*, *data stores*, and *data flows* between these. Every element in a DFD is systematically investigated for each of the threat types via a *mapping table* that indicates whether a threat type of a specific threat category is applicable to an element of a DFD model element type.

Threat modeling is widely used in industry as a cornerstone of secure development life-cycles (SDLs) and the importance of security- and privacy-by-design principles is increasingly recognized. Existing tool implementations [19, 26] highlight and exploit the *elicitative* nature of these approaches; i.e. they systematically iterate over the architectural elements encoded in the system DFD and the threat trees to identify and generate concrete threats (this is the *threat elicitation* step). In practical implementations, distinction is made between *per-element* [25, 8] and *per-interaction* [25, 27] threat elicitation, in which threats are identified respectively at the level of individual DFD elements or specifically at the level of interactions in the system (data flows).

Blockchain architecture and principles. Blockchain architectures are decentralized data stores in which many participants (nodes) hold a copy of shared data structure, and cooperate in a peer-to-peer fashion to reach consensus on a linked list of transactions (a digital transaction history, also called a *ledger*). Emerging from the context of digital crypto-currencies (and its best-known instance Bitcoin [20]), a blockchain is a shared data store among many participants, that is incrementally maintained and kept consistent through transactions. Individual participants (nodes) collect and validate transactions and package them in *blocks*.

To accept a block on the blockchain, distributed consensus is to be attained. In proof-of-work (PoW) based blockchain systems, this consensus is reached via the mechanism of mining. Miner participants are financially incentivized to solve mathematical and computationally-intensive problems. This in turn provides them with authority to append a new block to the blockchain, which is then shared in gossip-style among all peers in the peer-to-peer network.

3 Blockchain threat types

To ensure integrity, consistency, and availability at the level of data transactions, blockchain architectures implement a security model that is rooted upon a complex interplay of tactics and principles, involving distributed consensus mechanisms, providing economic incentives to participants, and cryptography. In their purest implementation (e.g., Bitcoin), blockchains are open and public ecosystems and participants are free to join and contribute. This gives rise to a number of security and privacy issues that in turn can be generalized to threat categories that should be considered when building blockchain-based applications. The survey study of Conti et al. [6] provides an exhaustive and in-depth analysis of blockchain threat types. We shortly discuss the most prominent threat types below.

Table 1. Classification and overview of the blockchain-specific security and privacy threat types identified in literature.

Threat Type	Enactment	Root cause	Risks/Consequences	Ref.
SECURITY THREAT TYPES				
Double spending	Block races	Consensus protocol Mining	Tampering	[15]
			Dishonest profits	[12]
			Disadvantage participants	[12]
			Wasting resources	
Mining Mining pools	Block races	Consensus protocol Mining activity Incentive-incompatibility	Double spending	[11]
	Deviating mining strategy		Disproportional gains	[23]
	Economic incentives		Wasting resources	[7]
			51%-attack	[17]
P2P network	Identification & connection of peers	Decentralization Internet overlay	Isolating nodes	[14]
	Deploying a large number of nodes		Denial of service	
			Double spending	
			Selfish mining	
PRIVACY THREAT TYPES				
Blockchain analysis	Transaction, address & user network	Transparency Public nature Pseudonymity	Linking transactions to each other	[22]
	Clustering heuristics			[18]
	Combining with off-chain data			[21]
	Active execution of transactions			[2]
	Behavior-based clustering			[9]
Network analysis	Anomalies in relay patterns	P2P network	Linking transactions to IP addresses	[16]
	Propagation of IP addresses and transactions			[3]
	TOR attacks			[4]
	via DoS-protection			
Key management	Bloomfilters in SPV	Cryptographic basis	Linking transactions	[21]
	Extraction of private keys		- to each other	[13]
			- to IP addresses	[10]

Security threat types. The root causes of the identified security threats include human and economic incentives of rational miners that maximize their benefits by grouping mining resources in mining pools, weaknesses of the network infrastructure upon which the P2P network is built, and issues caused by practical deployment.

The top half of Table 1 presents the most relevant security threat types. These represent attacks to the core principles of blockchain transaction processing: (i) exploiting race conditions in the consensus protocol, (ii) colluding among participants (miners) to obtain disproportional gains or to gain control over the network (51% attacks), and (iii) attacks to the network itself (denial of service, isolating nodes, etc).

Privacy threat types. Blockchains are essentially public, transparent, and shared data stores onto which transactions are processed in a pseudonymous manner (at the basis of addresses). The public nature leads to a number of privacy threat types related to identifying, linking, and accumulating information about how these addresses are used. As shown in the bottom half of Table 1, we distinguish between threats that act upon the information on the blockchain (blockchain analysis threats), upon transaction meta-data (e.g., addresses or pseudonyms used), and privacy threats related to key management.

Table 2. Categorical scale defined to assess the compatibility of STRIDE and LINDDUN with the identified blockchain-specific threat types.

Score Compatibility Meaning		
0	Problematic	The system model has to be created with a-priori and explicit knowledge of the threat type.
1	Problematic	The threat type is not covered by one of the existing threat categories.
2	Problematic	Threat type can be mapped to an existing threat category, but element- or interaction-based elicitation does not suffice.
3	Intermediate	Threat type can be mapped to an existing threat category, but the category definition has to be revised or broadened.
4	Positive	Threat type can be mapped onto an existing threat category but is not covered by a leaf in an existing threat tree.
5	Positive	There is a direct match between the threat type and a leaf in a threat tree. As such the threat can directly be found with with current threat modeling frameworks.

4 Compatibility assessment

To systematically investigate the compatibility of the existing threat modeling frameworks with the threat types discussed in the previous section, we have established the categorical scale presented in Table 2.

These criteria specifically aim at identifying (i) issues related to the expressivity of the DFD notation and incompatibilities that may arise in threat elicitation itself (scores 0, 2), (ii) the a-priori compatibility of the threat categories of STRIDE, respectively LINDDUN (scores 1, 3), or more specifically, (iii) compatibility with the existing threat trees (scores 4, 5).

Based on extensive expertise with the STRIDE and LINDDUN threat modeling approaches, and our assessment of the impact on existing tooling efforts [?], we explicitly value these scores, ranging from problematic to positive. These labels indicate our assessment of the discrepancy to the existing threat modeling frameworks.

To assess the compatibility, a DFD was created that models the essential blockchain functionality from the point of view of a typical Bitcoin-alike miner. This DFD is presented in Figure 1. This DFD is then used in a threat modeling exercise, applying both STRIDE and LINDDUN. Comparing the outcome threat catalog with the threat types in Table 1 allows up to assess the extent to which the threat types from literature can or could be elicited with current threat modeling tools and frameworks. Table 3 summarizes the results of compatibility assessment per threat type.

5 Conclusion

We have explored the compatibility between two established elicitative threat modeling frameworks that rely on DFD models, specifically STRIDE and LINDDUN, and distributed ledgers or blockchains –an architectural style representative of a contemporary decentralized storage systems. Our results confirm that for some threat types, there is a discernible gap. In our assessment, these incompatibilities are mainly caused by (i) limited expressivity of the DFD notation, (ii) the per-element or per-interaction elicitation paradigm that does not allow identifying threats that occur under more specific system context conditions, and finally (iii) the agnostic nature of these approaches, in terms of incentives and game-theoretic aspects that are essential to the blockchain security model.

In future work, we will address these issues through (i) extending the DFD notation with support for modeling concepts such as mining pools and large clusters of participants (potentially colluding adversaries), (ii) tool support for more sophisticated threat elicitation approaches, and (iii) tighter integration with modeling approaches (e.g. goal-driven threat assessments, game-theoretic models, etc) that allow reasoning about attacker capabilities, incentive compatibility and aid at determining game-theoretic equilibria in such threat models.

Acknowledgements. This research is partially funded by the Research Fund KU Leuven and the imec-ICON BOSS research project.

References

1. Almashaqbeh, G., Bishop, A., Cappos, J.: ABC: A Cryptocurrency-Focused Threat Modeling Framework. arXiv preprint arXiv:1903.03422 (2019)
2. Androuraki, E., Karame, G.O., Roeschlin, M., Scherer, T., Capkun, S.: Evaluating user privacy in bitcoin. In: International Conference on Financial Cryptography and Data Security. pp. 34–51. Springer (2013)
3. Biryukov, A., Khovratovich, D., Pustogarov, I.: Deanonymisation of clients in bitcoin p2p network. In: Proceedings of the 2014 ACM SIGSAC Conference on Computer and Communications Security. pp. 15–29. ACM (2014)
4. Biryukov, A., Pustogarov, I.: Bitcoin over tor isn’t a good idea. In: 2015 IEEE Symposium on Security and Privacy. pp. 122–134. IEEE (2015)
5. Carson, B., Romanelli, G., Walsh, P., Zhumaev, A.: Blockchain beyond the hype: What is the strategic business value. McKinsey & Company (2018)

6. Conti, M., Kumar, E.S., Lal, C., Ruj, S.: A survey on security and privacy issues of bitcoin. *IEEE Communications Surveys & Tutorials* **20**(4), 3416–3452 (2018)
7. Courtois, N.T., Bahack, L.: On subversive miner strategies and block withholding attack in bitcoin digital currency. *arXiv preprint arXiv:1402.1718* (2014)
8. Deng, M., Wuyts, K., Scandariato, R., Preneel, B., Joosen, W.: A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements. *Requirements Engineering* **16**(1), 3–32 (2011)
9. DuPont, J., Squicciarini, A.C.: Toward de-anonymizing bitcoin by mapping users location. In: *Proceedings of the 5th ACM Conference on Data and Application Security and Privacy*. pp. 139–141. ACM (2015)
10. Eskandari, S., Clark, J., Barrera, D., Stobert, E.: A first look at the usability of bitcoin key management. *arXiv preprint arXiv:1802.04351* (2018)
11. Eyal, I., Sirer, E.G.: Majority is not enough: Bitcoin mining is vulnerable. *Communications of the ACM* **61**(7), 95–102 (2018)
12. Finney, H.: Best practice for fast transaction acceptance-how high is the risk (2011)
13. Gervais, A., Capkun, S., Karame, G.O., Gruber, D.: On the privacy provisions of bloom filters in lightweight bitcoin clients. In: *Proceedings of the 30th Annual Computer Security Applications Conference*. pp. 326–335. ACM (2014)
14. Heilman, E., Kendler, A., Zohar, A., Goldberg, S.: Eclipse attacks on bitcoin’s peer-to-peer network. In: *24th USENIX Security Symposium* (2015)
15. Karame, G.O., Androulaki, E., Capkun, S.: Double-spending fast payments in bitcoin. In: *Proceedings of the 2012 ACM conference on Computer and communications security*. pp. 906–917. ACM (2012)
16. Koshy, P., Koshy, D., McDaniel, P.: An analysis of anonymity in bitcoin using p2p network traffic. In: *International Conference on Financial Cryptography and Data Security*. pp. 469–485. Springer (2014)
17. Kwon, Y., Kim, D., Son, Y., Vasserman, E., Kim, Y.: Be selfish and avoid dilemmas: Fork after withholding (faw) attacks on bitcoin. In: *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*. ACM (2017)
18. Meiklejohn, S., Pomarole, M., Jordan, G., Levchenko, K., McCoy, D., Voelker, G.M., Savage, S.: A fistful of bitcoins: characterizing payments among men with no names. In: *Proceedings of the 2013 conference on Internet measurement conference*. pp. 127–140. ACM (2013)
19. Microsoft Corporation: Microsoft Threat Modeling Tool 2016. <http://aka.ms/tmt2016> (2016)
20. Nakamoto, S., et al.: Bitcoin: A peer-to-peer electronic cash system (2008)
21. Nick, J.D.: Data-driven de-anonymization in Bitcoin. Master’s thesis, ETH-Zürich (2015)
22. Reid, F., Harrigan, M.: An analysis of anonymity in the bitcoin system. In: *Security and privacy in social networks*, pp. 197–223. Springer (2013)
23. Rosenfeld, M.: Analysis of bitcoin pooled mining reward systems. *arXiv preprint arXiv:1112.4980* (2011)
24. Shevchenko, N., Chick, T.A., O’Riordan, P., Scanlon, T.P., Woody, C.: Threat modeling: A summary of available methods (2018)
25. Shostack, A.: Threat Modeling: Designing for Security (2014)
26. Sion, L., Van Landuyt, D., Yskout, K., Joosen, W.: SPARTA: Security & privacy architecture through risk-driven threat assessment. *IEEE* (2018)
27. Sion, L., Wuyts, K., Yskout, K., Van Landuyt, D., Joosen, W.: Interaction-based privacy threat elicitation. In: *International Workshop on Privacy Engineering* (2018)
28. Tuma, K., Calikli, G., Scandariato, R.: Threat analysis of software systems: A systematic literature review. *Journal of Systems and Software* **144**, 275 – 294 (2018)